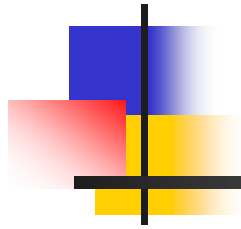
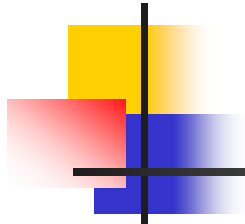


Hacking:

Information Gathering and Countermeasures

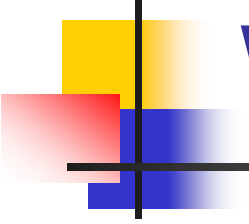


Presenter:
Chin Wee Yung



Hacking: Content

- Hacking terminology
- History of hacking
- Information gathering and countermeasures
- Conclusion



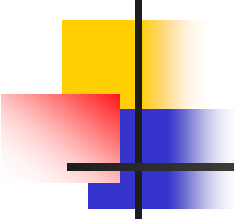
What is a Hacker?

- Refers to people skilled in computer programming, administration and security with legitimate goals

Famous hackers: Linus Torvalds, Larry Well

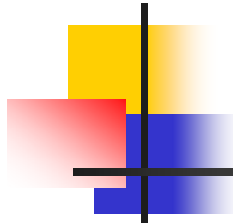
- Person able to exploit a system or gain unauthorized access through skill and tactics

Famous hackers: Kevin Mitnick, David L Smith



Type Of Hackers

- *White hat hacker* : attempt to break into systems or networks to help the system owners aware of security flaws
- *Black Hat hacker (cracker)* : exploits the vulnerabilities of systems or networks for private advantage
- *Grey Hat hacker (hybrid)* : compromise the security of systems or networks with no evil intentions



Hacker Ethics

- belief that it is an ethical duty of hackers to share their expertise by writing free software and facilitating access to information and computing resources
- belief that system hacking for fun and exploration is ethically acceptable as long as the hacker commits no theft, vandalism, or breach of confidentiality.

Hacking: History

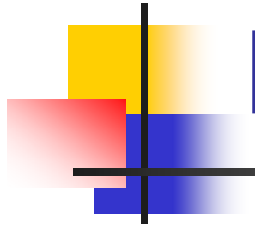
- **1972** John Draper(Captain Crunch) used a toy whistle to make free call
- **1983** The internet was formed
- Wargames, a movie about hacking, inspired many hackers
- **1984** Fred Cohen develops the first PC viruses
- **1989** Kevin Mitnick is convicted for stealing software from Digital Equipment



Hacking: History

- **1994** Russian hackers broke into Citibank and got away with \$10 million
- **1995** Kevin Mitnick was arrested for a second time for stealing 20,000 credit card numbers
- **1999** David L Smith arrested for writing the Melissa virus
- **2000** ILOVEYOU virus spreading worldwide
- **2004** the author of the NetSky and Sasser Internet worms, was arrested in northern Germany

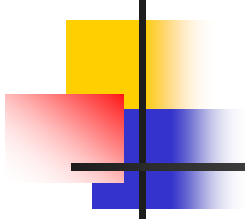




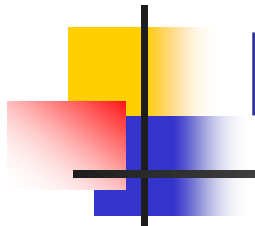
Hacking

Information Gathering

- 1) Footprinting
- 2) Scanning
- 3) Enumeration



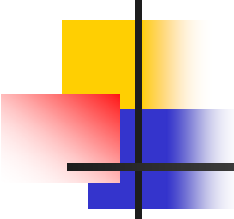
Footprinting



Hacking: Footprinting

What is footprinting?

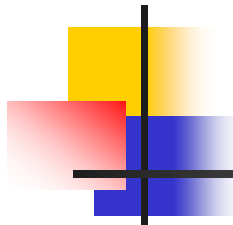
- Art of gathering information
- Profile of internet, remote access and intranet/extranet
- Determine the security posture of the target



Hacking: Footprinting

Critical information

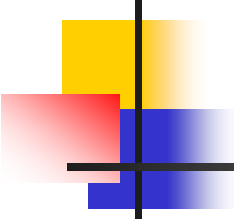
- Domain name
- Network blocks
- IP address reachable via internet
- TCP and UDP services in each system
- System architecture
- Access control mechanisms
- Intrusion detection systems



Hacking: Footprinting

Organization's website

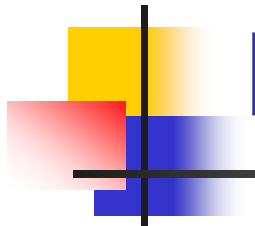
- Location, contact names and email address
- Security policies indicating the types of security mechanisms
- Security configuration options for their firewall
- Comments in HTML source code
- Mirror Tools: Wget (Unix), Teleport Pro (Windows)



Hacking: Footprinting

Whois Databases

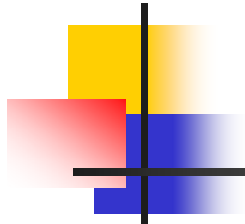
European: <http://www.ripe.net>
Asia Pacific: <http://www.apnic.net>
US military: <http://whois.nic.mil>
US gov: <http://www.nic.gov/whois.html>
World: <http://allwhois.com>
Singapore: <http://www.nic.net.sg>



Hacking: Footprinting

Information obtained from whois database

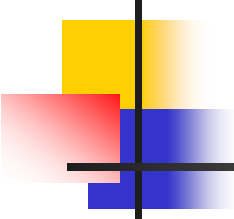
- Contact number: Wardialer eg 6874 xxxx
- Email address
- DNS servers IP addresses
- Registered IP addresses



Hacking: Footprinting

Countermeasures

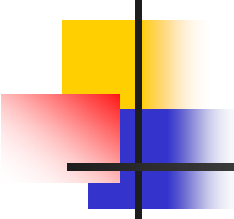
- Classify the type of information for the public
- Remove unnecessary information from the web pages
- Contact number not in organization's phone exchange (prevent war dialer)



Hacking: Footprinting

DNS Interrogation

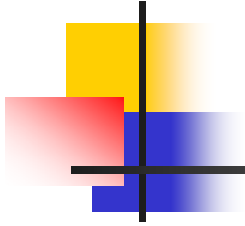
- Primary DNS provides zone transfer to secondary DNS
- Some DNS provide the zone data to anyone
- External DNS and internal DNS information not segregated
- Simply use “nslookup” command
- Obtained IP addresses, hostnames, OS



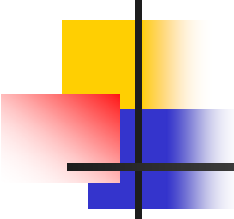
Hacking: Footprinting

DNS Interrogation: Countermeasures

- Disable or restrict zone transfer to authorized servers
- Separate internal DNS from external DNS



Hacking: Scanning



Hacking: Scanning

Determine if system is alive

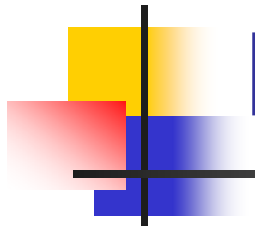
Methods

1) Ping sweep: ICMP packets

- Fping, nmap for UNIX
- Pinger, Ping Sweep for Windows

2) Port Scan: TCP packets

- Nmap can send TCP
- Hping2 can fragment TCP packets bypassing some access control devices

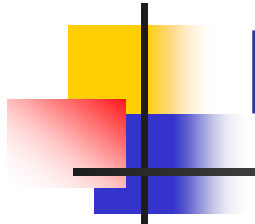


Hacking: Scanning

Port scanning

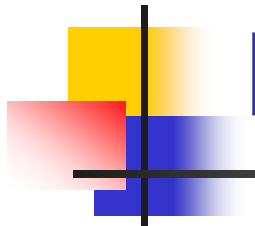
Objective

- Identify both TCP and UDP services
- Identify OS
- Identify the versions of application and services



Hacking: Scanning

Scanner	Win	Unix	UDP	TCP
Strobe		X		X
Udp_scan		X	X	
Nmap		X	X	X
Netcat	X	X	X	X
SuperScan	X			X
NetScanTools	X		X	X



Hacking: Scanning

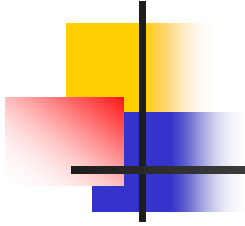
Port scanning: Countermeasures

Detentive

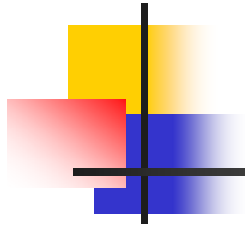
- Networking based IDS like Snort
- firewalls can detect port scan attempts
eg. ZoneAlarm(Windows)

Preventive

- Disable unnecessary services to minimize exposure



Hacking: Enumeration



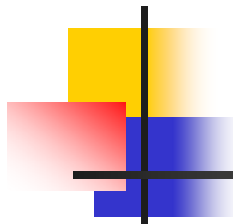
Hacking: Enumeration

What is Enumeration?

- The process of probing the identified services for known weaknesses

Information

- User account names
- Misconfigured shared resources
- Older software version with known vulnerabilities



Hacking: Enumeration

Common Techniques

1) Finger, TCP/UDP 79

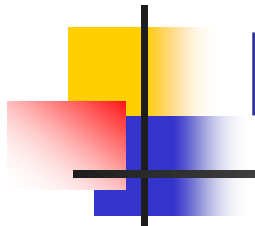
- Get logged-on user information and idle time

Countermeasure: disable finger service

2) HTTP HEAD request using Nmap

- Get web server version

Countermeasure: Change banner on your web servers

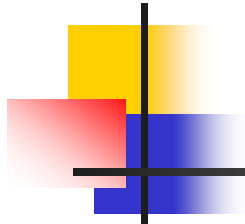


Hacking: Enumeration

Common Techniques

3) NetBIOS Name Service, UDP 137

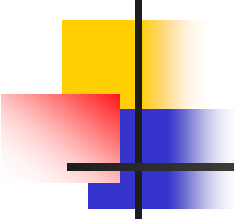
- Get window-based hosts in any domain using net view
- Obtained system name, MAC address using nbtstat



Hacking: Enumeration

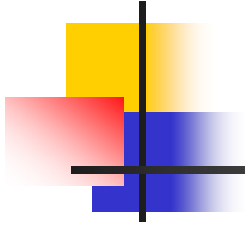
Countermeasures

- Set Restrict Anonymous to 2 in Win NT
- In Win XP/.NET server, configure the settings under Security Options correctly



Conclusion

- Information gathering first step of hacking
- No step by step in hacking
- Hacking tools are evolving fast
- Hacking knowledge is good fundamental for security specialists



~ The End ~